OLUWAFEMI TAIWO

Location: Lagos, Nigeria | Website: vharse-portfolio.netlify.app

PROFESSIONAL SUMMARY

Application Security Engineer and Penetration Tester. Hands-on background in web app exploitation (OWASP Top 10), Zero Trust API design, and CI/CD security automation. Spent the last year building custom security pipelines, writing detection rules for SIEM logs, implementing JWT/mTLS authentication layers, and auditing code for access control flaws.

TECHNICAL SKILLS

• **Penetration Testing:** Penetration Testing: Web App Penetration Testing, OWASP Top 10 (SQLi, XSS, Command Injection, BOLA / IDOR), API Security, Reconnaissance, Network Scanning (Nmap), Burp Suite, OWASP ZAP, Metasploit Framework, Fuzzing (ffuf / Gobuster), Manual Exploitation.

• **API & Application Defense:** Zero Trust Architecture, OAuth 2.1, Asymmetric Cryptography (RSA / PyJWT), RBAC & ABAC Access Controls, PostgreSQL Row-Level Security (RLS), Redis Rate-Limiting & Progressive IP Bans, Async Reverse Proxies (HTTPX / Nginx), Server-Side Input Sanitization, Docker.

• **DevSecOps & Pipeline Security:** GitHub Actions, CodeQL, Semgrep, SonarQube, Syft & Grype, Snyk, Gitleaks, Trivy, Software Bill of Materials (SBOM), OpenSSF Scorecard, Open Policy Agent (OPA / Rego), Docker, Terraform, Kubernetes, DefectDojo.

• **Systems, Networks & Diagnostics:** Wireshark Packet Analysis, Linux Syslog, SIEM Telemetry, Active Directory GPO Auditing, PowerShell Scripting.

INDEPENDENT SECURITY RESEARCH & BUG BOUNTY

Independent Security Researcher | HackerOne / Bugcrowd

• Conducted manual vulnerability assessments and business logic testing on live production web applications and APIs.

• Identified, documented, and responsibly disclosed valid security vulnerabilities, including access control flaws (BOLA/IDOR) and server-side injection vectors.

• Drafted structured Proof-of-Concept (PoC) reports detailing vulnerability root causes, severity metrics, and remediation guidance for engineering teams.

PROJECTS & LAB EXPERIENCE

DevSecOps:

Technologies: GitHub Actions, CodeQL, Semgrep, SonarQube, OPA (Rego), Trivy, Gitleaks, OpenSSF Scorecard, OWASP ZAP, DefectDojo, Docker.

• Built a modular CI/CD security pipeline using custom GitHub Actions to catch security flaws early in the development lifecycle.

• Applied Infrastructure-as-Code (IaC) checks using Open Policy Agent (OPA) with custom Rego policies (s3_check.rego) to stop misconfigurations before deployment.

• Integrated automated SBOM generation and OpenSSF Scorecard audits to monitor third-party dependencies and open-source supply chain risks.

• Set up automated SAST checks (CodeQL, Semgrep, SonarQube) and secret scanning (Gitleaks) to catch vulnerabilities and hardcoded keys before code gets merged.

• Automated DAST scans with OWASP ZAP and Trivy container checks, sending all findings to DefectDojo for tracking along with real-time Slack alerts.

Containerized Zero Trust API Gateway

Technologies: Python, FastAPI, Redis, Docker, PyJWT, Nginx, mTLS, OAuth 2.1

• Built and security-tested a Zero Trust API gateway using mutual TLS (mTLS) to verify device and service identities.

• Stopped authorization bypasses and session hijacking by setting up stateless PyJWT signature verification and OAuth 2.1 flows.

• Protected endpoints from brute-force and credential stuffing attacks using Redis-backed rate limiting and automatic IP blocking.

• Built Grafana dashboards with real-time alert rules to monitor active gateway traffic, rate-limit triggers, and authentication failures.

Custom Telemetry & Defensive SIEM Engine

Technologies: Linux Syslog, Python, Prometheus, Grafana, AI Analytics

• Built a custom backend SIEM log analysis system to capture live attack logs and study exploitation attempts.

• Wrote detection rules for SSH brute-force attempts and suspicious traffic, using AI analysis to evaluate attack patterns.

• Blocked brute-force IPs automatically at the firewall layer using custom iptables rules and systemd background services.

Active Directory Hardening & Privilege Audit Lab

Technologies: Windows Server, Active Directory, PowerShell, Group Policy Objects (GPOs)

• Audited enterprise Active Directory domains to identify privilege escalation paths, misconfigured ACLs, Kerberosting risks, and stale accounts.

• Wrote custom PowerShell scripts to automate AD audits and enforce baseline security settings across the domain using GPOs.

• Implemented least-privilege access models and Tiered Administration principles to mitigate lateral movement risks.

EDUCATION & PROFESSIONAL TRAINING

Diploma in Cybersecurity (Application & Network Security Track)

SQI College of ICT